

RAPPORT D'AVANCEMENT — PROJET DE FIN D'ANNÉE

Détection d'attaques Active Directory par Intelligence Artificielle

Stage	Security Operations Center (SOC) — Dataprotect, Business Unit Security Intelligence
Binôme	Maimouni Mohammed & Chafak Othmane
Encadrant Dataprotect	Benkirane Abbes
Date du rapport	4 août 2026

1. Objectif du projet

Concevoir une chaîne complète de détection d'attaques Active Directory : documenter les techniques d'attaque, les rejouer dans un laboratoire contrôlé, vérifier leur détection par un SIEM, corriger les angles morts identifiés, puis construire un agent d'intelligence artificielle de détection au niveau du contrôleur de domaine.

2. Avancement global

Phase	Description	Statut
1	Documentation de 48 attaques Active Directory (MITRE ATT&CK, Event IDs, règles, remédiation)	Terminé
2	Déploiement du lab GOAD-Light (AD vulnérable) sur VM Azure	Terminé
3	Installation du SIEM Wazuh (indexer, manager, dashboard) et agents sur les 3 machines	Terminé
4	Simulation des 12 attaques Active Directory et vérification de la détection Wazuh	Terminé (12/12)
5	Activation des audits Windows et écriture de règles de détection sur-mesure	En cours
6	Agent IA de détection (machine learning / détection d'anomalies)	À venir

3. Phase 4 — Simulation des attaques (terminée)

Les 12 attaques prévues ont été rejouées avec succès dans le laboratoire GOAD-Light (deux domaines liés par une relation de confiance : sevenkingdoms.local et north.sevenkingdoms.local), documentées individuellement, et leur niveau de détection par le SIEM Wazuh par défaut a été vérifié systématiquement.

#	Attaque	MITRE ATT&CK	Statut de détection
01	Kerberoasting	T1558.003	Partiel — connexion visible, motif RC4 non alerté
02	AS-REP Roasting	T1558.004	Angle mort — audit non configuré
03	Énumération LDAP	T1087.002	Angle mort — reconnaissance furtive
04	LLMNR/NBT-NS Poisoning	T1557.001	Angle mort — empoisonnement réseau
05	Password Spraying	T1110.003	Déecté — rafale d'échecs de connexion
06	DCSync	T1003.006	Angle mort critique — corrigé en Phase 5 (voir ci-dessous)

#	Attaque	MITRE ATT&CK	Statut de détection
07	Abus d'ACL	T1222.001	Détecté — ajout à Domain Admins
08	ADCS ESC1	T1649	Angle mort critique — compromission de la forêt invisible
09	Pass-the-Hash	T1550.002	Partiel — connexions visibles, non alertées
10	MSSQL (xp_cmdshell RCE)	T1210	Angle mort — audit de processus désactivé
11	Golden Ticket	T1558.001	Anomalie détectable — compte forgé, incohérence SID
12	Abus de trust inter-domaine	T1482	Anomalie détectable — compte forgé, incohérence SID

Synthèse du spectre de détection

Cette répartition constitue le résultat central de la Phase 4 : elle démontre qu'un SIEM déployé avec sa configuration par défaut ne détecte qu'une minorité des techniques d'attaque Active Directory modernes, ce qui justifie directement les travaux de la Phase 5.

Détecté (2 attaques)	Password Spraying, Abus d'ACL
Partiel / Anomalie détectable (4 attaques)	Kerberoasting, Pass-the-Hash, Golden Ticket, Abus de trust inter-domaine
Angle mort (6 attaques)	AS-REP Roasting, Énumération, LLMNR, DCSync, ADCS ESC1, MSSQL RCE

4. Phase 5 — Audits et règles de détection sur-mesure (en cours)

Cette phase vise à combler les angles morts identifiés en Phase 4, en deux temps : activer les catégories d'audit Windows manquantes sur les contrôleurs de domaine, puis écrire des règles de détection Wazuh capables de transformer les événements ainsi générés en alertes exploitables.

4.1 Activation des audits Windows

Les cinq catégories d'audit ciblées ont été activées avec succès sur les deux contrôleurs de domaine de la forêt (kingslanding pour sevenkingdoms.local, winterfell pour north.sevenkingdoms.local) :

- Directory Service Access — nécessaire à la détection du DCSync et de l'énumération
- Kerberos Authentication Service — nécessaire à la détection de l'AS-REP Roasting
- Kerberos Service Ticket Operations — nécessaire à la détection du Kerberoasting
- Certification Services — nécessaire à la détection de l'abus ADCS (ESC1)
- Process Creation — nécessaire à la détection de l'exécution de commandes via MSSQL

Une configuration supplémentaire (SACL de réplication sur l'objet racine du domaine) a également été mise en place pour permettre la journalisation effective des opérations de réplication utilisées par l'attaque DCSync.

4.2 Première règle de détection sur-mesure : DCSync

Une règle Wazuh personnalisée a été écrite, testée et validée pour détecter l'attaque DCSync — jusqu'ici l'angle mort le plus critique du projet, permettant une compromission totale du domaine sans laisser aucune trace exploitable. Après rejeu de l'attaque, la règle génère désormais une alerte de niveau 12 identifiant automatiquement le compte à l'origine de la réplication frauduleuse.

Résultat obtenu : DCSync est passé du statut d'angle mort critique à celui d'attaque détectée.

5. Prochaines étapes

- Écriture de règles de détection sur-mesure pour les angles morts restants : Kerberoasting (signature RC4 précise), ADCS ESC1 (demande et émission de certificat), MSSQL (exécution de commandes via xp_cmdshell)
- Re-test systématique de chaque attaque corrigée pour valider la détection de bout en bout
- Démarrage de la Phase 6 : conception de l'agent d'intelligence artificielle pour la détection comportementale (anomalies non couvertes par des règles de signature, telles que le Golden Ticket ou l'abus de trust inter-domaine)

6. Documentation et livrables

L'ensemble de la documentation technique (fiches d'attaques avec captures d'écran, guides de déploiement, glossaire, mapping MITRE ATT&CK) est disponible sur le dépôt GitHub public du projet :

<https://github.com/simohowaanaa/ai-driven-ad-attack-detection>